

11.3 - Mitigación de ataques de DHCP

Mitigación de ataques de DHCP

Revisión de ataque de DHCP

El objetivo de un ataque de agotamiento DHCP es que una herramienta de ataque como Gobbler cree una Denegación de servicio (DoS) para conectar clientes.

Recuerde que los ataques de agotamiento de DHCP pueden ser efectivamente mitigados usando seguridad de puertos, porque Gobbler usa una dirección MAC de origen única para cada solicitud DHCP enviada. Sin embargo mitigar ataques DHCP de suplantación de identidad requiere mas protección.

Gobbler podría configurarse para usar la dirección MAC de la interfaz real como la dirección Ethernet de origen, pero especifique una dirección Ethernet diferente en la carga útil de DHCP. Esto haría que la seguridad del puerto sea ineficaz porque la dirección MAC de origen sería legítima.

Los ataques de suplantación de DHCP se pueden mitigar mediante el uso de detección DHCP en puertos confiables.

Mitigación de ataques de DHCP

Mediante detección de DHCP

La inspección de DHCP filtra los mensajes de DHCP y limita el tráfico de DHCP en puertos no confiables.

- Los dispositivos bajo control administrativo (por ejemplo, switches, routers y servidores) son fuentes confiables.
- Las interfaces confiables (por ejemplo, enlaces troncales, puertos del servidor) deben configurarse explícitamente como confiables.
- Los dispositivos fuera de la red y todos los puertos de acceso generalmente se tratan como fuentes no confiables.

Se crea una tabla DHCP que incluye la dirección MAC de origen de un dispositivo en un puerto no confiable y la dirección IP asignada por el servidor DHCP a ese dispositivo.

- La dirección MAC y la dirección IP están unidas.
- Por lo tanto, esta tabla se denomina tabla de enlace DHCP snooping.

Pasos para implementar DHCP Snooping

Utilice las siguientes pasos para habilitar DHCP snooping:

Paso 1. Habilite DHCP snooping usando el comando **ip dhcp snooping** en modo global

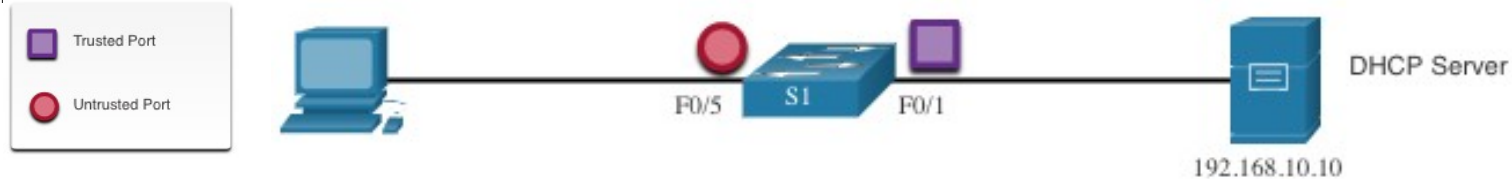
Paso 2. En los puertos de confianza, use el comando **ip dhcp snooping trust**.

Paso 3: En las interfaces que no son de confianza, limite la cantidad de mensajes de descubrimiento de DHCP que se pueden recibir con el comando **ip dhcp snooping limit rate *packets-per-second*** .

Paso 4. Habilite la inspección DHCP por VLAN, o por un rango de VLAN, utilizando el comando **ip dhcp snooping *vlan***.

Ejemplo de configuración de DHCP Snooping

Consulte la topología de ejemplo de indagación DHCP con puertos confiables y no confiables



- La inspección DHCP se habilita primero en S1.
- La interfaz ascendente al servidor DHCP es explícitamente confiable.
- F0/5 a F0/24 no son de confianza y, por lo tanto, su velocidad se limita a seis paquetes por segundo.
- Finalmente, la inspección DHCP está habilitada en VLANS 5, 10, 50, 51 y 52.

```
S1(config)# ip dhcp snooping
S1(config)# interface f0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# interface range f0/5 - 24
S1(config-if-range)# ip dhcp snooping limit rate 6
S1(config-if)# exit
S1(config)# ip dhcp snooping vlan 5,10,50-52
S1(config)# end
S1#
```

Ejemplo de configuración de DHCP Snooping (Cont.)

Utilice el comando **show ip dhcp snooping** para verificar la configuración de inspección DHCP.

Use el comando **show ip dhcp snooping binding** para ver los clientes que han recibido información de DHCP.

Nota: DHCP snooping también requiere Dynamic ARP Inspection (DAI).

```

S1# show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
5,10,50-52
DHCP snooping is operational on following VLANs:
none
DHCP snooping is configured on the following L3 Interfaces:
Insertion of option 82 is enabled
  circuit-id default format: vlan-mod-port
  remote-id: 0cd9.96d2.3f80 (MAC)
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Verification of giaddr field is enabled
DHCP snooping trust/rate is configured on the following Interfaces:

```

Interface	Trusted	Allow option	Rate limit (pps)
FastEthernet0/1	yes	yes	unlimited
FastEthernet0/5	no	no	6
FastEthernet0/6	no	no	6

```

S1# show ip dhcp snooping binding

```

MacAddress	IpAddress	Lease(sec)	Type	VLAN	Interface
00:03:47:B5:9F:AD	192.168.10.10	193185	dhcp-snooping	5	FastEthernet0/5

11.4 - Mitigación de ataques de ARP

Inspección dinámica de ARP

En un ataque típico el atacante puede enviar respuestas ARP no solicitadas, a otros hosts en la subred con la dirección MAC del atacante y la dirección IP de la puerta de enlace predeterminada. Para evitar la suplantación de ARP y el envenenamiento por ARP resultante, un interruptor debe garantizar que solo se transmitan las Solicitudes y Respuestas de ARP válidas.

La inspección dinámica(DAI) requiere de DHCP snooping y ayuda a prevenir ataques ARP así:

- No retransmitiendo respuestas ARP invalidas o gratuitas a otros puertos en la misma VLAN.
- Intercepta todas las solicitudes y respuestas ARP en puertos no confiables.
- Verificando cada paquete interceptado para una IP-to-MAC Binding válida.
- Descarte y registre ARP Replies no válidos para evitar el envenenamiento de ARP.
- Error-disabling deshabilita la interfaz si se excede el número DAI configurado de paquetes ARP.

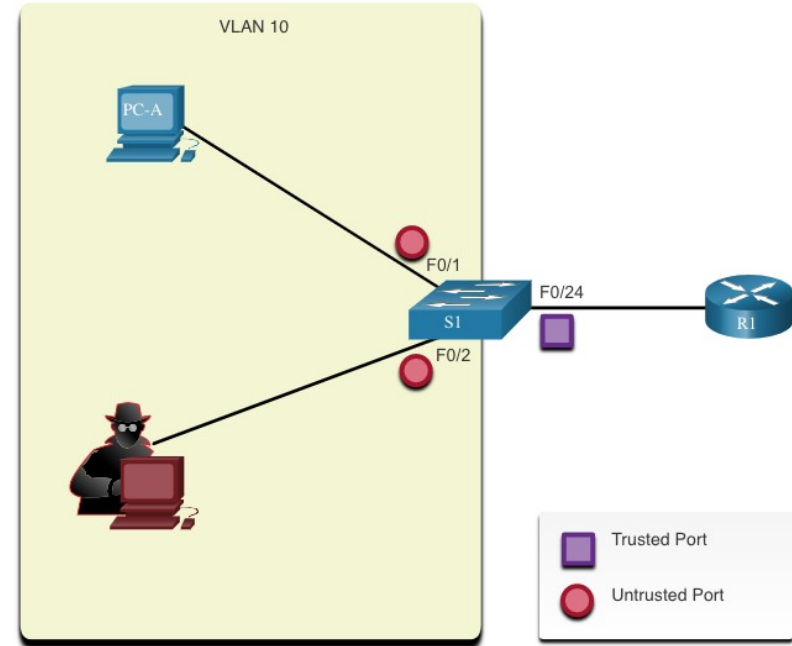
Mitigar los ataques ARP

Pautas de implementación de DAI

Para mitigar las probabilidades de ARP spoofing y envenenamiento ARP, siga estas pautas de implementación DAI:

- Habilite la detección de DHCP.
- Habilite la detección de DHCP en las VLAN seleccionadas.
- Habilite el DAI en los VLANs seleccionados.
- Configure las interfaces de confianza para la detección de DHCP y la inspección de ARP ("no confiable" es la configuración predeterminada).

Generalmente, es aconsejable configurar todos los puertos de switch de acceso como no confiables y configurar todos los puertos de enlace ascendente que están conectados a otros switches como confiables.



Ejemplo de configuración de DAI

En la topología anterior S1 está conectado a dos usuarios en la VLAN 10.

- DAI será configurado para mitigar ataques ARP spoofing y envenenamiento ARP.
- La inspección DHCP está habilitada porque DAI requiere que funcione la tabla de enlace de inspección DHCP.
- Continua, la detección de DHCP y la inspección de ARP están habilitados para la computadora en la VLAN 10.
- El puerto de enlace ascendente al router es confiable y, por lo tanto, está configurado como confiable para la inspección DHP y ARP.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10
S1(config)# ip arp inspection vlan 10
S1(config)# interface fa0/24
S1(config-if)# ip dhcp snooping trust
S1(config-if)# ip arp inspection trust
```

Ejemplo de configuración de DAI (Cont.)

DAI se puede configurar para revisar si hay direcciones MAC e IP de destino o de origen:

- **MAC de destino** Comprueba la dirección MAC de destino en el encabezado de Ethernet con la dirección MAC de destino en el cuerpo ARP.
- **MAC de origen**- Comprueba la dirección MAC de origen en el encabezado de Ethernet con la dirección MAC del remitente en el cuerpo ARP.
- **Dirección IP**- Comprueba el cuerpo ARP para direcciones IP no válidas e inesperadas, incluidas las direcciones 0.0.0.0, 255.255.255.255 y todas las direcciones de multidifusión IP.

Ejemplo de configuración de DAI (Cont.)

El **comando de configuración global: ip arp inspección validate {[src-mac] [dst-mac] [ip]}** se utiliza para configurar DAI para descartar paquetes ARP cuando las direcciones IP no son válidas.

- Se puede usar cuando las direcciones MAC en el cuerpo de los paquetes ARP no coinciden con las direcciones que se especifican en el encabezado Ethernet.
- Note como en el siguiente ejemplo, sólo un comando puede ser configurado.
- Por lo tanto, al ingresar múltiples

comandos de validación de inspección de arp sobre escribe el comando anterior.

- Para incluir más de un método de validación, ingréselos en la misma línea de comando como se muestra y verifíquelos en la siguiente salida.

```
S1(config)# ip arp inspection validate ?
dst-mac  Validate destination MAC address
ip        Validate IP addresses
src-mac   Validate source MAC address
S1(config)# ip arp inspection validate src-mac
S1(config)# ip arp inspection validate dst-mac
S1(config)# ip arp inspection validate ip
S1(config)# do show run | include validate
ip arp inspection validate ip
S1(config)# ip arp inspection validate src-mac dst-mac ip
S1(config)# do show run | include validate
ip arp inspection validate src-mac dst-mac ip
S1(config)#
```